your minimum viable product, somehow got some funding, and now need to put together an API and a simple web client. You'll soon be the new Mark Zuckerberg, rich beyond your dreams, and considering a run for President.

Just one small problem: your investors are worried about security. Now you must convince them that you've got this covered, and that they won't be a laughingstock on launch night or faced with hefty legal liabilities later. Where do you start?

Although this scenario might not be much like anything you're working on, if you're reading this book the chances are that at some point you've had to think about the security of an API that you've designed, built, or been asked to maintain. In this chapter, you'll build a toy API example, see examples of attacks against that API, and learn how to apply basic secure development principles to eliminate those attacks.

2.1.1 Overview of the Natter API

The Natter API is split into two REST endpoints, one for normal users and one for moderators who have special privileges to tackle abusive behavior. Interactions between users are built around a concept of social spaces, which are invite-only groups. Anybody can sign up and create a social space and then invite their friends to join. Any user in the group can post a message to the group and it can be read by any other member of the group. The creator of a space becomes the first moderator of that space.